

DPDP COMPLIANCE AUDIT

docs

Digital Personal Data Protection Act 2023



62/100

Grade C — Needs Work

Scanned: 22 March 2026

Files indexed: 80

Languages: react, reactflow, docusaurus, typescript, javascript, node

CONFIDENTIAL — Internal Use Only

DPDP Compliance Scan Report

The application collects framework preferences via URL parameters and stores them in localStorage. The primary risk surface is the potential for cross-site scripting (XSS) if the framework parameter is not properly sanitized before being stored in localStorage.

Total findings: 9
 MEDIUM: 3
 INFO: 2
 PASS: 1

Tech Stack: react, reactflow, docusaurus, typescript, javascript

Risk Profile: The application collects framework preferences via URL parameters and stores them in localStorage. The primary risk surface is the potential for cross-site scripting (XSS) if the framework parameter is not properly sanitized before being stored in localStorage.

Compliance score by section

DPDP Section	Weight	Score	Status
Section 6	22	0/22 (0%)	FAIL
Section 6(6)	8	8/8 (100%)	PASS
Section 8(1)	18	18/18 (100%)	PASS
Section 8	10	10/10 (100%)	PASS
Section 8(3)	8	8/8 (100%)	PASS
Section 8(4)	8	0/8 (0%)	FAIL
Section 8(6)	8	4.0/8 (50%)	WARN
Section 9	6	6/6 (100%)	PASS
Section 11	6	2.1/6 (35%)	FAIL
Section 16	4	2.0/4 (50%)	WARN
Section 5	2	2/2 (100%)	PASS
Section 13 — Grievance Redressal		4/4 (100%)	PASS

Estimated Total Remediation Effort: 2.2–7.5 engineering days

Rule	Section	Severity	File
CONSENT_MISSING_REPO_LEVEL	Section 6 — Consent	MEDIUM	REPO-WIDE
AUDIT_TRAIL_MISSING	Section 8(4) — Audit Trail	MEDIUM	N/A
NO_LOGGING_DETECTED	Section 8(6) — Breach	LOW	N/A
CROSS_BORDER_TRANSFER_RISK	Section 16 — Cross-Border Transfer	LOW	src/components/LatestInstallation.jsx
DATA_ACCESS_MISSING	Section 11 — Right to Access	MEDIUM	N/A
DATA_PORTABILITY_MISSING	Section 11 — Data Portability	LOW	N/A
NO_THIRD_PARTY_DETECTED	Section 5 — Notice	INFO	N/A

NO_THIRD_PARTY_DATA_SHARING	Section 5 — Purpose Limitation	INFO	N/A
CONSENT_WITHDRAWAL_PRESENT	Section 6(6) — Consent Withdrawal	PASS	src/components/homepage/HomeFooter.jsx

30-Day Remediation Roadmap

The following plan prioritises findings by severity and estimated effort. Complete Week 1 items before your next security review.

Week 2 — High Priority (10–34 hours)

Address within 2 weeks — short fixes with significant compliance impact.

- Consent Missing Repo Level — REPO-WIDE (4–16 hrs)
- Audit Trail Missing (4–12 hrs)
- Data Access Missing (2–6 hrs)

Week 4 — Advisory (8–26 hours)

Address before next compliance review.

- No Logging Detected (2–6 hrs)
- Cross Border Transfer Risk — components/LatestInstallation.jsx (4–12 hrs)
- Data Portability Missing (2–8 hrs)

Total estimated remediation effort: 18–60 hours (2.2–7.5 engineering days)

Details

Finding 1 of 9

[Section 6 — Consent]

1. [MEDIUM] CONSENT_MISSING_REPO_LEVEL — CODEBASE-WIDE**Estimated fix time:** 4–16 hours

No consent mechanism detected anywhere in the repository.

Risk:

The absence of a consent mechanism means that personal data may be collected or processed without explicit user agreement, violating DPDP Section 6. This can lead to non-compliance penalties and loss of user trust.

Fix:

1. Implement a consent management system (e.g., a cookie banner with granular consent options) that captures user consent before collecting or processing personal data.
2. Integrate consent status checks into data processing workflows to ensure data is only handled when consent is granted.
3. Store consent records securely and provide users with the ability to withdraw consent.
4. Update privacy policies to clearly outline data processing activities and consent requirements.

DPDP:

Section 6 — Consent

Example:

```
import React, { useState } from 'react'; function ConsentBanner() { const [visible, setVisible] = useState(true); const handleAccept = () => { // Logic to grant consent setVisible(false); }; if (!visible) return null; return ( <div className="consent-banner"> <p>We use cookies to improve your experience. Do you consent?</p> <button onClick={handleAccept}>Accept</button> </div> ); }
```

Finding 2 of 9

[Section 8(4) — Audit Trail]

2. [MEDIUM] AUDIT_TRAIL_MISSING — N / A**Estimated fix time:** 4–12 hours

No audit trail infrastructure detected. DPDP Section 8(4) requires complete records of personal data processing activities. No access logging, audit model, or change tracking found in the codebase.

Risk:

The lack of an audit trail means that processing activities involving personal data cannot be adequately tracked, making it difficult to demonstrate compliance or investigate data breaches as required by DPDP Section 8(4). This hinders accountability and transparency.

Fix:

1. Integrate a logging framework (e.g., Winston, Pino for Node.js) to capture relevant events.
2. Define an audit model to log key data processing activities, including data access, modification, and deletion, along with user and timestamp information.
3. Ensure audit logs are stored securely and retained according to policy.
4. Implement mechanisms to review and analyze audit logs for suspicious activities or compliance checks.

DPDP:

Section 8(4) — Audit Trail

Example:

```
import winston from 'winston'; const logger = winston.createLogger({ level: 'info', format: winston.format.json(), transports: [ new winston.transports.File({ filename: 'audit.log' }) ], }); function processUserData(userId, data) { logger.info('User data processed', { userId, data }); // ... processing logic ... }
```

Finding 3 of 9

[Section 8(6) — Breach]

3. [LOW] NO_LOGGING_DETECTED — N / A**Estimated fix time:** 2–6 hours

No logging library detected anywhere. Breach detection and reporting may be inadequate.

Risk:

The absence of logging makes it difficult to detect, investigate, and report data breaches as required by DPDP Section 8(6). This can lead to delayed response times and increased impact from security incidents.

Fix:

1. Integrate a robust logging library (e.g., Winston, Pino for Node.js) into the application.
2. Configure the logger to capture critical events, errors, and potential security anomalies.
3. Ensure logs are stored securely and retained for an appropriate period.
4. Establish procedures for monitoring and analyzing logs to identify and respond to potential breaches.

DPDP:

Section 8(6) — Breach

Example:

```
import pino from 'pino'; const logger = pino({ level: process.env.LOG_LEVEL || 'info', });
function handleRequest(req, res) { logger.info(`Received request: ${req.method} ${req.url}`);
try { // ... request handling ... logger.info('Request processed successfully'); } catch
(error) { logger.error('Error processing request', error); } }
```

Finding 4 of 9

[Section 16 — Cross-Border Transfer]

4. [LOW] CROSS_BORDER_TRANSFER_RISK — src / components / LatestInstallation.jsx:19**Evidence snippet:** 'https://b72qj023g7.execute-api.ap-south-1.amazonaws.com/default/android-core-latest',**Estimated fix time:** 4–12 hours

Foreign cloud storage/CDN detected with PII models in repo. Cross-border transfer risk.

Risk:

Processing personal data using foreign cloud storage or CDNs without adequate safeguards, as suggested by the rule, risks non-compliance with DPDP Section 16. This could lead to data being subject to foreign laws that do not offer equivalent protection, increasing the risk of unauthorized access or misuse.

Fix:

1. Review all third-party services (CDNs, cloud storage) used for storing or processing personal data to identify their data residency and transfer practices.
2. If personal data is transferred internationally, ensure appropriate safeguards are in place (e.g., Standard Contractual Clauses, Binding Corporate Rules, or explicit consent).
3. Update data processing agreements with third-party providers to include clauses addressing cross-border data transfer requirements.
4. Document all cross-border data transfers and the safeguards implemented.

DPDP:

Section 16 — Cross-Border Transfer

Example:

```
import React from 'react'; // Assuming a component that might interact with a CDN or cloud
storage function ImageDisplay({ imageUrl }) { // In a real scenario, this might involve logic
to check CDN origin or data residency // For demonstration, we'll just render an image tag.
return ( <img src={imageUrl} alt="Content" /> ); } export default ImageDisplay;
```

Finding 5 of 9

[Section 11 — Right to Access]

5. [MEDIUM] DATA_ACCESS_MISSING — N / A**Estimated fix time:** 2–6 hours

No endpoint detected that allows authenticated users to retrieve their own personal data. Under DPDP Section 11, Data Principals have the right to access information about their personal data being processed.

Risk:

The absence of a data access endpoint violates the Data Principal's right to access their personal data, potentially leading to non-compliance and loss of user trust.

Fix:

1. Create a new API endpoint (e.g., `/users/me/data`) using FastAPI's routing.
2. Implement authentication middleware to ensure only the logged-in user can access this endpoint.
3. In the endpoint function, query the database for the authenticated user's personal data.
4. Return the retrieved data in a JSON response, adhering to a clear and documented schema.

DPDP:

Section 11 — Right to Access: Data Principals have the right to obtain confirmation that their personal data is being processed and to access that data.

Example:

```
from fastapi import APIRouter, Depends from sqlalchemy.orm import Session from .database
import get_db from .schemas import UserDataSchema from .auth import get_current_user router =
APIRouter() @router.get('/users/me/data', response_model=UserDataSchema) def
get_my_data(current_user: dict = Depends(get_current_user), db: Session = Depends(get_db)): #
Fetch user data from DB using current_user['id'] user_data = db.query(User).filter(User.id ==
current_user['id']).first() return user_data
```

Finding 6 of 9

[Section 11 — Data Portability]

6. [LOW] DATA_PORTABILITY_MISSING — N / A**Estimated fix time:** 2–8 hours

No data export or portability endpoint detected. DPDP Section 11 requires Data Fiduciaries to provide personal data in a commonly used, machine-readable format upon request.

Risk:

The lack of a data portability endpoint prevents users from exercising their right to receive their personal data in a usable format, hindering data mobility and potentially leading to non-compliance.

Fix:

1. Create a new API endpoint (e.g., `/users/me/export`) using FastAPI's routing.
2. Implement authentication middleware to ensure only the logged-in user can access this endpoint.
3. In the endpoint function, fetch the user's data and format it into a common, machine-readable format (e.g., JSON or CSV).
4. Return the data as a downloadable file with appropriate content-type headers.

DPDP:

Section 11 — Data Portability: Data Fiduciaries shall provide personal data in a commonly used, machine-readable format.

Example:

```
from fastapi import APIRouter, Depends, Response from sqlalchemy.orm import Session from
.database import get_db from .auth import get_current_user import json router = APIRouter()
@router.get('/users/me/export') def export_my_data(current_user: dict =
Depends(get_current_user), db: Session = Depends(get_db)): # Fetch user data from DB user_data
= db.query(User).filter(User.id == current_user['id']).first() data_to_export =
json.loads(user_data.to_json()) # Assuming a to_json method return
Response(content=json.dumps(data_to_export), media_type='application/json')
```

Finding 7 of 9

[Section 5 — Notice]

7. [INFO] NO_THIRD_PARTY_DETECTED — N / A

No known third-party analytics or tracking SDKs detected in codebase.

Finding 8 of 9

[Section 5 — Purpose Limitation]

8. [INFO] NO_THIRD_PARTY_DATA_SHARING — N / A

No third-party data sharing detected.

Finding 9 of 9

[Section 6(6) — Consent Withdrawal]

9. [PASS] CONSENT_WITHDRAWAL_PRESENT — src / components / homepage / HomeFooter.jsx

Consent withdrawal mechanism detected. Found in:
src/components/homepage/HomeFooter.jsx (line 241)

AI-Identified Compliance Gaps

The following gaps were identified by AI analysis and cross-validated. These are advisory observations, not verified rule violations. Human review is required before acting on these findings.

[AI-INFERRED] Missing consent withdrawal mechanism for localStorage

Confidence: 60%

Section 6(6) Consent Withdrawal

The repository stores 'framework preference' in `localStorage` (src/client/set-framework.js:5). While the rule engine identified a lack of explicit consent for this storage, there is no evidence of a user-facing mechanism or endpoint to withdraw this consent or clear the stored data.

Recommendation: Implement a user-facing control (e.g., a button in a privacy settings section or a cookie banner preference center) that allows users to explicitly clear the `docusaurus.tab.framework` key from `localStorage` and prevent its future storage.

[AI-INFERRED] Purpose limitation for third-party search queries

Confidence: 65%

Section 5 Purpose

Search queries are submitted to third-party services: Algolia (DocSearch, src/theme/SearchBar/index.jsx:177) and Dyte AI Chatbot (src/theme/SearchBar/index.jsx:115). The rule engine noted `third\_party\_checked: false` and `CROSS\_BORDER\_TRANSFER\_RISK`. There is no explicit check or mention of purpose limitation for how these third parties process potentially PII-containing search queries beyond providing search results.

Recommendation: Review the data processing agreements and terms of service with Algolia and Dyte AI Chatbot to ensure that search query data is processed strictly for the purpose of providing search functionality. If secondary purposes exist, implement explicit user consent for such processing.

[AI-INFERRED] Absence of Data Protection Officer contact information

Confidence: 40%

Section 10 DPO

The repository context does not indicate any presence of Data Protection Officer (DPO) contact information or a designated point of contact for data protection queries within the application or associated documentation.

Recommendation: Add a dedicated section in the website's footer, 'About Us', or 'Privacy Policy' page that clearly states the contact information for data protection queries or, if applicable, the appointed Data Protection Officer.

Deep Compliance Review

Overall Risk: CRITICAL

The application exhibits critical DPDP compliance risks stemming from systemic issues in data transparency, consent management, and PII security across multiple architectural layers. Key concerns include undocumented third-party data sharing, client-side storage without explicit user consent, and

insufficient controls for PII handling during token forwarding. These deficiencies, coupled with a hardcoded secret, create a high potential for data breaches and non-compliance with data protection regulations, requiring immediate and comprehensive remediation.

E

Most Critical Action: Implement a comprehensive data mapping exercise to document all PII flows, especially those involving third parties, and establish explicit consent mechanisms for data sharing and client-side storage.

Layer Breakdown

Data Models & Storage — 0 finding(s). No compliance issues identified in this layer. The provided code is a UI component for an interactive tour, representing a database visually, and does not handle or process any data, PII, or implement any data protection controls directly.

Configuration & Secrets — 1 finding(s). This configuration layer primarily defines static content routing for a documentation site. The main DPDP concern identified is the potential hardcoding of a secret or PII, indicated by the `REDACTED\_POSSIBLE\_SECRET` placeholder, which poses a significant confidentiality risk if not properly managed. Otherwise, the file does not appear to handle or process personal data directly.

API Routes & Controllers — 1 finding(s). This layer primarily serves static API documentation and does not appear to directly collect or process sensitive user data through forms or explicit input fields. The main compliance concern identified is the client-side storage of user preferences without explicit consent, which is a common DPDP requirement for data stored on user devices.

Third-Party & PII Flows — 3 finding(s). This layer primarily contains UI components and a visualization of architectural data flows. While the UI components themselves do not directly handle PII, the interactive tour's data flow diagrams reveal critical architectural patterns involving third-party data sharing, data storage, and PII-relevant token transmission. The absence of explicit DPDP controls (like consent, data minimization, or security measures) within the depicted flows represents significant compliance risks that need to be addressed at the architectural and implementation levels.